

**Instituição de Ensino: Proz Educação
Técnico em Desenvolvimento de Sistemas**

Nathália Renata e Thiago Junior

ATIVIDADE AVALIATIVA - Reconhecimento de Vulnerabilidade

**Cidade: Contagem - MG
Ano: 2025**

Sumário

1. Introdução: A Essência da Cibersegurança Defensiva.....	3
2. Vulnerabilidade em Segurança da Informação.....	4
3. CVE	4
4. CVSS	4
5. Exploit VS Vulnerabilidade	5
6. Vulnerabilidade SSH 7.4, Apache 2.2 sem TLS, SMBv1, FTP	6
6.1 Detalhamento das Vulnerabilidades Críticas	7
7. Scam de Rede	8
7.1 Execução e Identificação de Serviços.....	8
7.2 Análise de Vulnerabilidades Relatadas.....	9
8. CONCLUSÃO	10

Introdução: A Essência da Cibersegurança Defensiva

No universo dinâmico e sempre em evolução da cibersegurança, a capacidade de identificar, quantificar e mitigar fraquezas é a base de qualquer estratégia defensiva robusta. Esta discussão navegou pelos conceitos cruciais que regem essa prática, começando pela distinção fundamental entre Vulnerabilidade— uma falha ou fraqueza passiva no código ou configuração—e Exploit—o código ativo ou técnica desenvolvida para tirar proveito dessa falha. Para gerenciar esse risco de maneira eficaz, a comunidade global de segurança utiliza sistemas padronizados. O CVE (Common Vulnerabilities and Exposures) fornece o identificador único e universal para cada vulnerabilidade conhecida publicamente, enquanto o CVSS (Common Vulnerability Scoring System) oferece a pontuação numérica e a classificação de gravidade, permitindo que as organizações priorizem seus esforços de correção. A aplicação desses conceitos se torna palpável ao analisarmos serviços de rede comuns, como SSH, Apache HTTP, SMBv1 e FTP, onde a desatualização ou configurações inseguras (como login anônimo ou falta de TLS) transformam-se em portas abertas para ataques.

VULNERABILIDADE EM SEGURANÇA DA INFORMAÇÃO

Uma vulnerabilidade em segurança da informação é uma falha ou fraqueza inerente à estrutura, funcionalidade, implementação ou configuração de um sistema, rede, processo ou até mesmo em pessoas, que pode ser explorada por uma ameaça (como um hacker ou um malware) para comprometer a segurança das informações.

CVE

Uma CVE significa Common Vulnerabilities and Exposures (Vulnerabilidades e Exposições Comuns).

É um sistema de catalogação internacionalmente reconhecido para identificar, definir e catalogar vulnerabilidades de segurança cibernética que são conhecidas publicamente em softwares e hardwares.

O principal objetivo do sistema CVE é fornecer um identificador padrão para cada vulnerabilidade. Isso permite que profissionais de segurança, fornecedores de software e usuários se refiram à mesma falha de forma consistente, facilitando a comunicação e a coordenação de esforços para corrigir e mitigar ameaças.

CVSS

O Common Vulnerability Scoring System (CVSS) é um framework aberto e padronizado para avaliar a gravidade das vulnerabilidades de segurança de softwares e hardwares.

Ele atribui uma pontuação numérica de 0.0 a 10.0 e uma classificação qualitativa (como "Média", "Alta", "Crítica"), ajudando as organizações a priorizar quais vulnerabilidades devem ser corrigidas primeiro com base no seu risco.

Esta pontuação varia de 0.0 a 10.0 e representa as características permanentes e imutáveis da vulnerabilidade. Ela é dividida em dois subgrupos:

Subgrupo	Foco	Exemplo de Métricas
Métricas de Exploração	Avaliação a facilidade e forma como a vulnerabilidade pode ser explorada	Vetor de ataque (remoto, rede adjacente, local). Complexidade do ataque.
Métricas de Impacto	Avaliam o dano potencial que o sucesso da exploração pode causar no sistema	Impactos na confidencialidade, integridade e disponibilidade dos dados/sistema.

EXPLOIT VS VULNERABILIDADE

A vulnerabilidade é a falha ou fraqueza, e o exploit é a ferramenta ou ação que usa essa falha para causar dano.

Vulnerabilidade é corrigida através de patches ou atualizações de software/firmware. Exemplos disso são um buffer overflow, uma senha padrão fraca, falta de validação de entrada de usuário em um formulário web.

Já o exploit tem como objetivo obter acesso, escalar privilégios, instalar um payload (carga maliciosa, como um ransomware ou backdoor) ou causar negação de serviço.

Tipos Comuns:

Exploit Remoto: É executado pela rede, sem acesso prévio ao sistema.

Exploit Local: Requer que o atacante já tenha algum acesso ao sistema, geralmente usado para elevar privilégios (ex: de um usuário comum para administrador).

Exploit Zero-Day (Dia Zero): Explora uma vulnerabilidade que é desconhecida pelos desenvolvedores do software, o que significa que não há correção (patch) disponível no momento do ataque.

VULNERABILIDADE SSH 7.4, APACHE 2.2 SEM TLS, SMBv1, FTP

Serviço	Descrição (O que é?)	Porta Padrão	Vulnerabilidades Chave
SSH 7.4	Secure Shell. Protocolo de rede para acesso remoto seguro (criptografado) e execução de comandos em servidores.	TCP 22	Desatualizado (End-of-Life/Obsoleto), vulnerável a CVEs de 2016-2017 (como CVE-2016-10009 e outras), ataques de Denial of Service (DoS), e pode ser afetado por ataques SWEET32 se cifras fracas forem permitidas.
Apache 2.2 sem TLS	Apache HTTP Server. Servidor web amplamente utilizado para hospedar sites e aplicações. TLS (Transport Layer Security) é a criptografia (HTTPS).	TCP 80 (HTTP)	Tráfego Não Criptografado (risco de Man-in-the-Middle), Versão Obsoleta (End-of-Life), vulnerável a inúmeras CVEs de DoS e Execução Remota de Código (RCE) (ex: falhas de buffer).
SMBv1	Server Message Block (v1). Protocolo de compartilhamento de arquivos e impressoras da Microsoft.	TCP 445 e/ou TCP/UDP 137-139	Protocolo Totalmente Obsoleto e Inseguro. Altamente vulnerável a exploits de execução remota de código, como EternalBlue (usado nos ataques WannaCry e NotPetya). Permite ataques de pass-the-hash e Denial of Service.
FTP com Login Anônimo	File Transfer Protocol. Protocolo para transferir arquivos entre sistemas cliente e servidor.	TCP 21 (Controle)	Risco

Detalhamento das Vulnerabilidades Críticas

1. SSH 7.4

Vulnerabilidade Intrínseca: O OpenSSH 7.4 é uma versão antiga (lançada em 2016) e já possui diversas vulnerabilidades de alta severidade catalogadas (CVEs).

Ataques de Execução de Código (Local): Vulnerabilidades como a CVE-2016-10009 podem permitir a um atacante local ou com controle sobre um socket encaminhado executar código arbitrário.

Negação de Serviço (DoS): Existem falhas (como CVE-2016-10708) que permitem a um atacante remoto não autenticado causar um crash no daemon SSH, resultando em interrupção do serviço.

2. Apache 2.2 sem TLS (HTTP)

Principal Falha: Falta de Criptografia: Ao operar em HTTP (porta 80) e sem TLS (HTTPS), todo o tráfego (incluindo cookies de sessão, credenciais de login e dados de usuários) é transmitido em texto puro. Um invasor na mesma rede pode facilmente interceptar (sniffing) esses dados.

Versão Obsoleta: A série Apache 2.2 é considerada End-of-Life (EOL), o que significa que não recebe mais atualizações de segurança ou correções de bugs. Ele contém inúmeras falhas conhecidas de DoS, RCE e vazamento de informações.

3. SMBv1

Principal Falha: Exploitabilidade Crítica (EternalBlue): O SMBv1 contém falhas de execução remota de código (RCE) de altíssima severidade (como a MS17-010 explorada pelo EternalBlue). Essa vulnerabilidade permite que um atacante não autenticado (sem login/senha) execute código malicioso no servidor, resultando em controle total do sistema.

Design Inseguro: O protocolo é inerentemente inseguro e foi substituído por versões mais modernas (SMBv2 e SMBv3) que mitigam esses riscos. Ele também é suscetível a ataques de downgrade e pass-the-hash.

4. FTP com Login Anônimo

Risco de Vazamento de Dados: Permitir login anônimo (geralmente com o nome de usuário anonymous e qualquer e-mail como senha) expõe todos os arquivos disponíveis para essa conta. Se a conta anônima tiver acesso a diretórios sensíveis ou arquivos de configuração, isso pode levar a uma grande divulgação de informações (information disclosure).

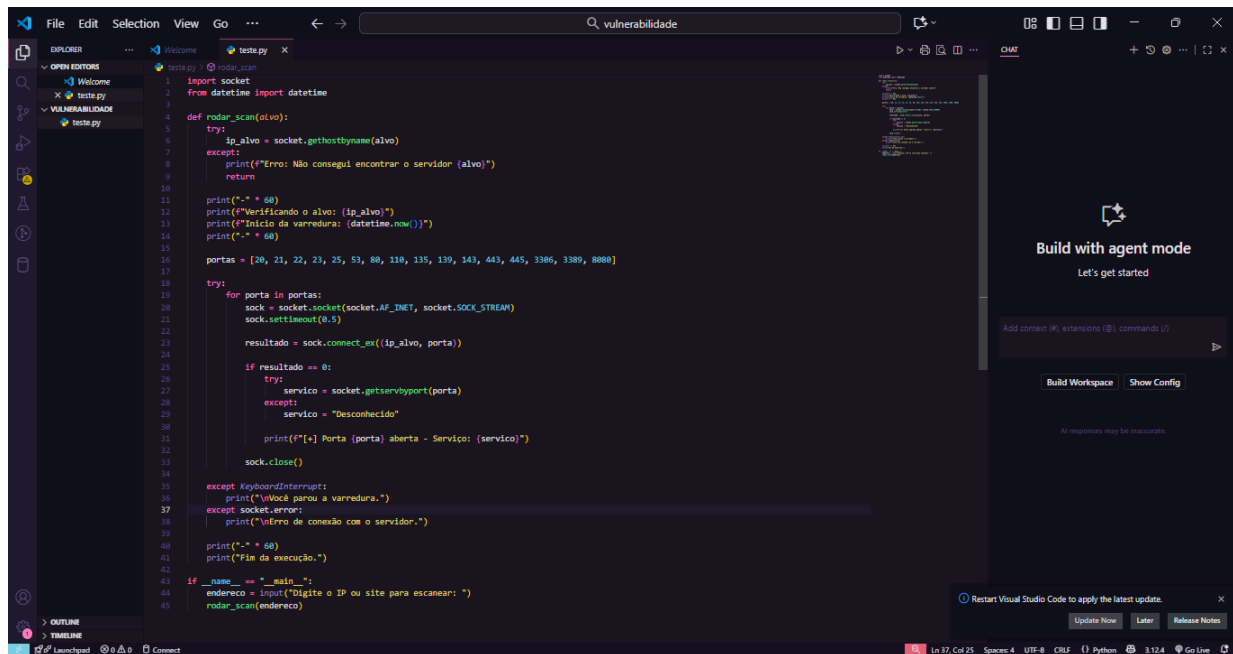
Risco de Upload Malicioso: Se o login anônimo permitir uploads, um atacante pode carregar malware, scripts maliciosos ou páginas de phishing para o servidor.

Falta de Criptografia: Sem criptografia, a conexão é vulnerável a sniffing, o que também expõe credenciais de login não anônimas.

Scam de Rede

Código-Fonte do Scanner

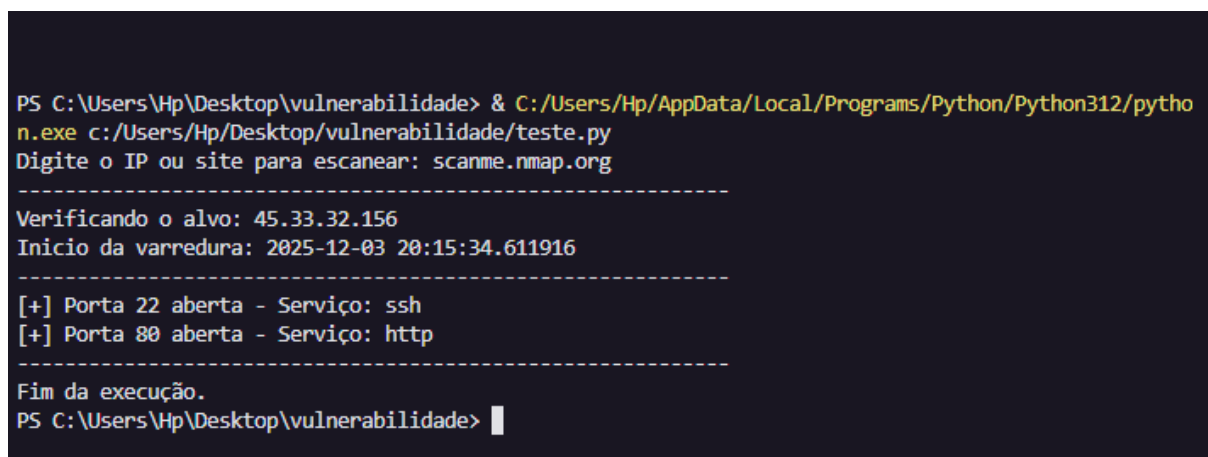
Abaixo está o código-fonte do *port scanner* utilizado na varredura:



```
1 import socket
2 from datetime import datetime
3
4 def rodar_scan(alvo):
5     try:
6         ip_alvo = socket.gethostbyname(alvo)
7     except:
8         print("**Erro: Não consegui encontrar o servidor (alvo)")
9         return
10
11     print("-" * 60)
12     print(f"Verificando o alvo: {ip_alvo}")
13     print(f"Início da varredura: {datetime.now()}")
14     print("-" * 60)
15
16     portas = [20, 21, 22, 23, 25, 53, 80, 110, 135, 139, 143, 443, 445, 3386, 3389, 8080]
17
18     try:
19         for porta in portas:
20             sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
21             sock.settimeout(0.5)
22
23             resultado = sock.connect_ex((ip_alvo, porta))
24
25             if resultado == 0:
26                 try:
27                     servico = socket.getservbyport(porta)
28                 except:
29                     servico = "Desconhecido"
30
31                 print(f"[+] Porta {porta} aberta - Serviço: {servico}")
32
33             sock.close()
34
35     except KeyboardInterrupt:
36         print("\nVocê parou a varredura.")
37     except socket.error:
38         print("\nErro de conexão com o servidor.")
39
40     print("-" * 60)
41     print("Fim da execução.")
42
43 if __name__ == "__main__":
44     endereco = input("Digite o IP ou site para escanear: ")
45     rodar_scan(endereco)
```

7.1 Execução e Identificação de Serviços

A varredura foi executada no alvo autorizado scanme.nmap.org, identificando as portas 22 (SSH) e 80 (HTTP) como abertas.



```
PS C:\Users\Hp\Desktop\vulnerabilidade> & C:/Users/Hp/AppData/Local/Programs/Python/Python312/python.exe c:/Users/Hp/Desktop/vulnerabilidade/teste.py
Digite o IP ou site para escanear: scanme.nmap.org
-----
Verificando o alvo: 45.33.32.156
Início da varredura: 2025-12-03 20:15:34.611916
-----
[+] Porta 22 aberta - Serviço: ssh
[+] Porta 80 aberta - Serviço: http
-----
Fim da execução.
PS C:\Users\Hp\Desktop\vulnerabilidade> |
```

Imagem 2 – Resultado da varredura de portas no servidor scanme.nmap.org.

7.2 Análise de Vulnerabilidades Relatadas

A análise de risco foi focada nos serviços identificados na varredura (SSH e HTTP).

1. Serviço: SSH (Secure Shell) - Porta 22

Detalhe	Descrição
Vulnerabilidade	User Enumeration (OpenSSH)
CVE Associada	CVE-2018-15473
Gravidade (CVSS v3.1)	5.3 (Média)
Descrição	Falha de reconhecimento que permite a um atacante determinar se um nome de usuário é válido ou não no servidor, facilitando a elaboração de ataques de força bruta.

CONCLUSÃO

A jornada através dos sistemas CVE e CVSS, e a análise das vulnerabilidades em serviços de rede, reforça uma verdade inegável: a segurança não é um estado, mas sim um processo contínuo. A existência de um identificador (CVE) e uma pontuação de risco (CVSS) servem como ferramentas essenciais para transformar o caos das vulnerabilidades em uma fila de trabalho gerenciável. A priorização baseada na pontuação de CVSS (Crítica, Alta, Média) é vital, garantindo que os recursos sejam focados nas fraquezas que representam o maior risco de exploração por exploits ativos. Em última análise, a defesa eficaz de qualquer ambiente de TI reside na proatividade: a eliminação de protocolos obsoletos como SMBv1, a garantia de que todos os serviços (como SSH e Apache) estejam sempre atualizados para as versões mais recentes e seguras, e a desativação de funcionalidades de alto risco, como o login FTP anônimo. Ao internalizar esses padrões e adotar uma postura de vigilância constante, as organizações podem proteger melhor seus ativos contra as ameaças em constante evolução.